Information Security and Data Classification Policy

1. Purpose

This policy defines how Halcyon Dynamics classifies information and the minimum controls that protect each class. Every document, dataset and system must be assigned a classification by its data owner.

2. Classification levels

- Public: information approved for release to the public, such as marketing material and published job adverts. No special controls are needed.
- Internal: the default level for business information not intended for the public, such as internal procedures and the intranet. It may be shared with any employee or contractor.
- Confidential: information whose disclosure could harm the company or its customers, such as contracts, financial forecasts, customer data and employee records. Access is limited to people with a business need.
- Restricted: the most sensitive information, such as payment card data, authentication secrets, merger and acquisition plans and security vulnerability reports. Access is granted by name and reviewed every 90 days.

3. Handling rules

- Labelling: Confidential and Restricted documents must carry a sensitivity label in Microsoft 365. Labels apply encryption automatically.
- Sharing externally: Internal data may be shared externally only under an NDA. Confidential data requires data owner approval. Restricted data must never be shared externally without approval from the Chief Information Security Officer.
- Email: Confidential data sent outside the company must be encrypted using the Encrypt button in Outlook. Restricted data must not be sent by email.
- Storage: Restricted data may only be stored in designated Restricted SharePoint sites or shared drive folders. It must never be stored on a laptop's local disk.
- Printing: Confidential and Restricted documents must be printed with Secure Print and collected immediately.
- Disposal: paper documents classified Confidential or above must be placed in locked shred bins. Devices are wiped by IT using certified tools.

4. Access control

- Access follows the principle of least privilege and is approved by the data owner.
- Privileged (administrator) accounts are separate from day-to-day accounts and must use a FIDO2 security key for MFA.
- Access rights for Confidential and Restricted data are reviewed every 90 days. Unconfirmed access is removed automatically.
- Accounts of leavers are disabled at 17:00 on their last working day (see KB-0010).

5. Security incidents

A security incident is any event that may compromise the confidentiality, integrity or availability of company information. Examples include a lost laptop, a phishing email that was clicked, malware alerts, and data sent to the wrong recipient.

- Report security incidents immediately by phone on extension 4357. Do not try to investigate on your own.
- Do not turn off a device suspected of malware infection. Disconnect it from the network and wait for instructions.
- Personal data breaches must be assessed by the Data Protection Officer within 24 hours, because regulators may need to be notified within 72 hours.

6. Exceptions

Exceptions to this policy must be requested through the Service Desk portal under Security > Policy Exception. Approved exceptions are time-limited to a maximum of 12 months and are recorded in the risk register.